

RESEARCH ON

Cybersecurity Status of Banking & Financial Institutions of Nepal

Threats · Compliance · Governance · Resilience · Regulatory Progress

Data Sources:

Nepal Police Cyber Bureau | Nepal Rastra Bank (NRB)
FIU-Nepal Strategic Analysis Report 2024 | NRB Cyber Resilience Guidelines 2023

May 2025

Abstract

Nepal's banking and financial sector is navigating an unprecedented era of digital transformation while simultaneously confronting a rapidly expanding cyber threat landscape. This research paper presents a comprehensive assessment of the cybersecurity status of Banks and Financial Institutions (BFIs) in Nepal, drawing on primary data from the Nepal Police Cyber Bureau, Nepal Rastra Bank (NRB) directives, the Financial Intelligence Unit (FIU-Nepal) Strategic Analysis Report 2024, and verified incident records up to fiscal year 2024/25.

The paper examines the current digital banking landscape, catalogues the top cyber risks facing Nepali BFIs, analyzes the compliance and governance framework mandated by the NRB, highlights rising threats, evaluates regulatory progress, and proposes recommendations for building systemic cyber resilience. Key findings reveal that cyber-enabled financial fraud in Nepal reached NPR 1.79 billion in fiscal year 2024/25, cybercrime complaints have grown more than 10,850% since 2018/19, and institutional responses — while improving — remain critically under-resourced relative to the scale and sophistication of modern attacks.

Keywords: *Cybersecurity, Nepal, BFIs, Nepal Rastra Bank, Cyber Bureau, Financial Fraud, Cyber Resilience, Digital Banking, NRB, Fintech Security*

1. Introduction

Nepal's financial sector has experienced a seismic digital shift over the past decade. The proliferation of mobile banking, digital wallets, payment service providers, and internet banking has extended financial access to millions of previously unbanked Nepalis. By 2025, more than 23.7 million users were registered for mobile banking services, and 1.9 million for internet banking — figures that were negligible just a decade ago. This digital inclusion has been a cornerstone of Nepal's economic development agenda.

However, the rapid expansion of digital financial services has dramatically enlarged the attack surface for cybercriminals. Nepal's banks and financial institutions now manage vast quantities of sensitive customer data, process billions of rupees in daily electronic transactions, and operate complex interconnected payment networks — all of which represent high-value targets for both opportunistic and organized cyber threat actors.

The Nepal Police Cyber Bureau, established in June 2018, has recorded an astronomical rise in cybercrime complaints — from 2,301 complaints in fiscal year 2019/20 to 19,730 in 2023/24, representing a more than 10,850% increase over six years. In fiscal year 2024/25, 18,926 cases were registered — averaging 52 cases per day — with financial fraud constituting a significant and growing proportion. The fiscal losses from cyber-enabled financial fraud totaled NPR 1.79 billion in FY 2024/25 alone.

Nepal Rastra Bank (NRB), the country's central bank and primary regulator of BFIs, has responded with a series of escalating regulatory measures, culminating in the issuance of the Cyber Resilience Guidelines (CRG) in August 2023 — a landmark framework mandating comprehensive cyber risk management across all licensed institutions. Yet significant gaps remain in enforcement capacity, institutional readiness, workforce expertise, and legislative infrastructure.

This paper provides a structured, evidence-based analysis of Nepal's financial cybersecurity landscape, intended for policymakers, financial regulators, banking executives, cybersecurity professionals, and researchers engaged in understanding and strengthening the resilience of Nepal's financial system.

2. Current Digital Banking Landscape in Nepal

2.1 Digital Adoption and Financial Inclusion

Nepal's digital financial ecosystem has expanded at a pace that outstrips many comparable economies. The following key indicators define the current landscape:

Indicator	Status (2024-2025)
Mobile Banking Users	23.7 million+
Internet Banking Users	1.9 million+
Mobile Connections	39 million+ (exceeds total population)
Internet Penetration	55%+ of population (16.5 million online)
Digital Wallet Users (eSewa, Khalti)	Tens of millions
Commercial Banks (Class A)	20 licensed institutions
Development Banks (Class B)	17 licensed institutions
Finance Companies (Class C)	17 licensed institutions
Microfinance Institutions (Class D)	64 licensed institutions

Table 1: Nepal's Digital Banking Landscape (FY 2024-25)

2.2 Growth of Digital Transactions

Nepal's digital payment ecosystem has seen exponential growth, driven by the COVID-19 pandemic, government digitization programs, and aggressive fintech expansion. Real-Time Gross Settlement (RTGS), Scripless Securities Settlement System (SSSS), Connectips, and mobile payment platforms have collectively transformed the payments landscape. Over 150,000 households are on fixed broadband, and 24 million subscribers use 3G/4G mobile connectivity.

This digitization has been broadly welcomed for its efficiency and inclusion benefits. However, the rapid onboarding of users — many with limited digital literacy — has created a large population of potential victims for cybercriminals. The intersection of rapid adoption and inadequate user education has proven to be one of the most critical vulnerabilities in Nepal's financial cyber defense posture.

2.3 Key Incident Reference: The NIC Asia SWIFT Heist (2017)

A watershed moment for Nepal's banking cybersecurity consciousness came in October 2017, when NIC Asia Bank — one of Nepal's largest private-sector commercial banks — suffered a targeted SWIFT network compromise. Attackers exploited poor IT hygiene practices: SWIFT-dedicated computers were used for general internet activity, including personal email access, and staff had been granted unauthorized remote access to the SWIFT server. Hackers initiated USD 4.4 million in fraudulent transfers to accounts in the United States, United Kingdom, Japan, Singapore, and two other countries.

The NRB intervened immediately, issuing international alerts that led to the recovery of approximately USD 3.9 million. However, USD 580,000 had already been released. The incident prompted NRB to convene emergency meetings of IT heads from all commercial banks and laid the groundwork for subsequent IT governance reforms. KPMG India was commissioned to conduct forensic analysis, a process that highlighted systemic weaknesses including vacancies in senior IT positions and the absence of robust access controls.

3. Top Cyber Risks Facing Nepal's BFIs

Based on data from the Nepal Police Cyber Bureau, NRB incident reports, the FIU-Nepal 2024 Strategic Analysis Report, and sector-specific research, the following cyber risks have been identified as most prevalent and consequential for Nepali BFIs:

3.1 Phishing and Social Engineering

Phishing attacks — whether via email, SMS (smishing), or voice calls (vishing) — remain the most pervasive entry vector for financial fraud in Nepal. Since 2025, there has been a marked surge in phishing campaigns conducted through WhatsApp and Telegram, targeting account holders at commercial banks. Fraudsters impersonate bank officials, NRB personnel, or law enforcement to manipulate victims into disclosing One-Time Passwords (OTPs), account numbers, and PIN codes.

OTP fraud is a particularly damaging variant in Nepal. Scammers, posing as bank or digital wallet representatives, trick users into sharing authentication codes, enabling unauthorized transactions within minutes. From 2020/21 to 2023/24, 665 complaints specifically related to eSewa were registered with the Cyber Bureau; an additional 266 were filed in the first nine months of FY 2024/25 alone. For banks, 683 complaints were recorded from 2019/20 through 2023/24, with 178 additional cases in partial FY 2024/25.

3.2 Ransomware and Malware

Ransomware — which encrypts institutional data and demands cryptocurrency payments for decryption keys — has emerged as a critical threat to Nepali BFIs, cooperatives, and associated government infrastructure. A co-operative and bank ransomware wave spanning 2022-2024 saw multiple Nepali banks and state portals compromised by ransomware strains. Modern ransomware operators use a 'double extortion' model: data is exfiltrated before encryption, and victims are threatened with public release of sensitive customer KYC data if the ransom is not paid.

Banking-specific botnets including Dyre, Dridex, and variants of WannaCry have been identified in the regional threat landscape. Nepal's under-resourced institutions, where 93% of networks reportedly harbor penetrable vulnerabilities, represent attractive targets for ransomware operators operating in the Asia-Pacific region.

3.3 Data Breaches and Unauthorized Access

The 2024 F1Soft digital payment platform breach stands as a landmark incident in Nepal's financial cybersecurity history. Attackers exploited an unpatched API vulnerability in F1Soft's infrastructure, resulting in NPR 34.2 million in unauthorized transactions and the exposure of 1.2 million customer records. The breach also implicated Citizens Bank's Durbar Marg branch, where the hacked software system was allegedly hosted, raising serious questions about third-party vendor security and supply chain risk management.

Additionally, the Nepal Rastra Bank itself suffered a data breach in 2024, exposing sensitive financial information and gravely undermining confidence in the security of the country's apex financial regulator. In the same year, a mid-2025 API exploit at a major Nepali bank — exploiting third-party vendor weaknesses — led to the theft of customer records, underscoring the systemic nature of API security vulnerabilities.

3.4 ATM and Card Fraud

ATM skimming, card cloning, and unauthorized point-of-sale transactions remain significant sources of financial loss for Nepali customers and banks. Physical tampering of ATM machines — installing skimming devices and pinhole cameras — enables criminals to harvest card data and PINs. The proliferation of ATM networks across the country, often deployed with insufficient physical security monitoring, has amplified this risk. Card-not-present fraud has also increased with the growth of online commerce.

3.5 Insider Threats

Insider threats — whether from disgruntled employees, negligent staff, or compromised personnel — represent a consistently underestimated risk in Nepal's banking sector. The NIC Asia SWIFT heist of 2017 demonstrated how insider access and lax IT discipline can directly enable large-scale external attacks. Junior IT staff without adequate training or supervision were managing the bank's most critical financial messaging infrastructure. Principles of least-privilege access, which restrict employee data access to what is strictly necessary, are inconsistently applied across Nepal's BFIs.

3.6 DDoS Attacks and Infrastructure Disruption

Distributed Denial of Service (DDoS) attacks have been weaponized against Nepali digital infrastructure on multiple occasions. In January 2023, approximately 1,500 government websites were disrupted in a coordinated DDoS campaign that also affected operations at Tribhuvan International Airport. The 2025 DDoS attack on the TIA Immigration portal caused nationwide travel disruption. Financial institutions remain vulnerable to such attacks, particularly during politically sensitive periods or following geopolitical tensions.

3.7 Cryptocurrency Scams and Cyber-Enabled Financial Fraud

Cryptocurrency-related fraud has emerged as a rapidly growing category of financial cybercrime in Nepal. Fake investment schemes promising exceptional returns through crypto trading have defrauded victims of average losses of NPR 250,000 per case in 2024. Investment scams orchestrated through social media platforms and messaging applications have proliferated. According to the FIU-Nepal Strategic Analysis Report 2024, individuals aged 19-30 constitute 70% of those involved in cyber-enabled financial frauds — many as unwitting 'money mules' recruited to receive and transfer fraudulent proceeds.

3.8 Supply Chain and Third-Party Vendor Risks

Nepal's BFIs increasingly rely on third-party technology vendors, cloud service providers, and payment aggregators. This interconnectedness creates systemic vulnerability: a breach in any single vendor can cascade across multiple financial institutions simultaneously. The F1Soft breach exemplified this risk, affecting both the payment platform and the bank hosting its software. API security has emerged as a critical weak point, with unsecured API endpoints enabling unauthorized data access and transaction manipulation.

4. Compliance & Governance Framework

4.1 Nepal Rastra Bank's Regulatory Architecture

Nepal Rastra Bank exercises comprehensive supervisory authority over all licensed BFIs under the dual framework of the Nepal Rastra Bank Act 2058 (2002) and the Banks and Financial Institutions Act (BAFIA) 2073 (2017). BAFIA authorizes NRB to conduct inspections, issue directives, and take corrective actions — including suspension of management, license revocation, and forced amalgamation — against non-compliant institutions. All BFIs classified as Class A (commercial banks), Class B (development banks), Class C (finance companies), and Class D (microfinance institutions) are subject to NRB's IT and cybersecurity governance requirements.

4.2 NRB IT Policy and Guidelines (2012)

The foundational document governing IT risk management in Nepali commercial banks is the NRB Information Technology Guidelines, first issued in August 2012. The guidelines establish 12 IT policies and 10 operational guidelines encompassing IT governance, information security, staff education, disclosure requirements, outsourcing management, system operations, business continuity, auditing, and fraud management. Key requirements include:

- Board-approved IT strategy, policies, and procedures with defined roles and responsibilities
- Mandatory identification and documentation of all electronic attacks, with monthly reporting to NRB
- Implementation of multi-level security for information systems
- Regular risk analysis before adopting any new technology or system
- Customer authentication systems prior to electronic system access
- Published dispute resolution processes and customer privacy policies on bank websites
- IS (Information Security) Audit at minimum every two years, with outsourcing permitted if internal expertise is lacking

Banks were required to submit an implementation action plan to NRB's Bank Supervision Department within six months of the guidelines' issuance, with full compliance expected within two years. Compliance is verified during periodic on-site and off-site supervision exercises.

4.3 Cyber Resilience Guidelines 2023 — A Landmark Mandate

The NRB's issuance of the Cyber Resilience Guidelines (CRG) in August 2023 represents the most significant advancement in Nepal's financial cybersecurity regulatory framework. Developed under Monetary Policy FY 2022/23 directive number 128, the CRG was formulated by a dedicated

NRB taskforce in consultation with the Nepal Bankers' Association, Payment System Operators (PSOs), and Payment Service Providers (PSPs). The framework is modeled on the Bank for International Settlements (BIS) Guidance on Cyber Resilience for Financial Market Infrastructures.

The CRG applies to all NRB-licensed institutions: Class A, B, C, and D BFIs, as well as all licensed PSOs and PSPs. It establishes five primary risk management categories and three overarching components:

Category / Component	Key Requirements
1. Governance	Board-approved cyber resilience strategy; designated CISO-level responsibility; cyber risk integrated into enterprise risk management
2. Identification	Comprehensive risk assessments identifying critical operations, assets, data flows, and threat vectors; third-party dependency mapping
3. Protection	Strong security controls aligned with ISO 27001; multi-factor authentication; network segmentation; encryption of data in transit and at rest
4. Detection	Continuous monitoring capabilities; Security Operations Center (SOC) or equivalent; real-time alerting for anomalous transactions
5. Response & Recovery	Comprehensive incident response plans; tested recovery procedures; defined RTO/RPO targets; mandatory reporting of significant incidents to NRB
Testing (Overarching)	Regular penetration testing, vulnerability assessments, and cyber resilience exercises (TLPT — Threat-Led Penetration Testing)
Situational Awareness (Overarching)	Threat intelligence sharing; participation in sectoral information-sharing frameworks; monitoring of emerging threats
Learning & Evolving (Overarching)	Post-incident reviews; regular updates to cyber resilience frameworks based on evolving threat landscape and lessons learned

Table 2: NRB Cyber Resilience Guidelines 2023 — Framework Summary

4.4 AML/CFT Compliance and Customer Due Diligence

NRB's AML/CFT (Anti-Money Laundering/Combating the Financing of Terrorism) framework requires all BFIs to maintain robust Know Your Customer (KYC) protocols, conduct ongoing

customer due diligence (CDD), monitor transactions for suspicious activity, and file Suspicious Transaction Reports (STRs) and Suspicious Activity Reports (SARs) with the Financial Intelligence Unit (FIU-Nepal). In January 2025, NRB issued strengthened directives mandating:

- Establishment of a dedicated AML/CFT department or unit headed by a compliance officer at managerial level
- Electronic verification of customers' national identity card details when opening accounts (effective Magh 1, 2081 BS / January 15, 2025)
- Validation that mobile numbers provided by customers genuinely belong to them
- Enhanced categorization of Politically Exposed Persons (PEPs) with specific monitoring protocols for current high-ranking officials, former officials, foreign PEPs, and international organization officials

The FIU-Nepal's 2024 Strategic Analysis Report on Cyber-Enabled Frauds — the fourth in its series — analyzed STR/SAR/TTR data from commercial and development banks, identifying significant post-COVID increases in CEF-related suspicious transaction reporting. The report found that fraudsters commonly use multiple accounts across different BFIs and PSPs to launder proceeds.

4.5 Corporate Governance and IT Risk Oversight

NRB's consolidated directives require banks to integrate cybersecurity risks into their Board-level governance structures. IT risk must be addressed within enterprise risk management frameworks. Key governance requirements include:

- Board-approved IT and cybersecurity policies reviewed at least annually
- IT Steering Committees with senior management representation
- Information Security Officer (ISO) role with direct reporting lines to senior management
- Mandatory IS audits with findings reported to the Board Audit Committee
- Two-factor authentication mandatory for payment service providers and operators
- Disaster recovery sites and tested Business Continuity Plans (BCPs)

Despite these requirements, enforcement has been uneven. In Q3 FY 2024/25, NRB fined 11 financial institutions for regulatory violations including inadequate risk management and non-compliance with directives. Among those penalized were five commercial banks, with one incurring a fine of NPR 148.525 million for failing to meet mandatory sectoral lending targets — signaling the NRB's escalating enforcement posture.

5. Rising Cyber Threats in Nepal's BFIs

5.1 The Scale of the Threat — By the Numbers

The quantitative trajectory of cybercrime in Nepal's financial sector is alarming. The following data, sourced from the Nepal Police Cyber Bureau and NRB, establishes the scale of the challenge:

Metric	Figure	Source
Total cybercrime complaints (FY 2024-25)	18,926 cases (avg. 52/day)	Nepal Police Cyber Bureau
Total cybercrime complaints (FY 2023-24)	19,730 cases	Nepal Police Cyber Bureau
Total cybercrime complaints (FY 2019-20)	2,301 cases	Nepal Police Cyber Bureau
Growth in complaints (2018/19 to 2024/25)	10,850%+	Nepal Police Cyber Bureau
Cyber-enabled financial fraud losses (FY 2024-25)	NPR 1.79 billion	Nepal Police Cyber Bureau
F1Soft breach loss (2024)	NPR 34.2 million	Cyber Bureau / Media Reports
NIC Asia SWIFT heist loss (2017)	USD 580,000 (net unrecovered)	NRB / Media Reports
Bank-related complaints (2019/20–2023/24)	683 cases	Nepal Police Cyber Bureau
eSewa-related complaints (2020/21–2023/24)	665 cases	Nepal Police Cyber Bureau
Financial scams as % of registered cybercrimes	~40%	NRB / Cyber Bureau Data
Avg. crypto scam loss per victim (2024)	NPR 250,000	Nepal Police Cyber Bureau
Age profile of CEF perpetrators (19-30)	70% of involved individuals	FIU-Nepal SAR 2024
Cyber Bureau personnel (IT experts)	106 total (28 IT specialists)	Cyber Bureau
Investigator-to-complaint ratio	~1:650	Cyber Bureau / Analysis

Table 3: Key Cybercrime and Financial Fraud Statistics (Nepal, 2017-2025)

5.2 Emerging Threat Vectors

Beyond established fraud typologies, several emerging threat vectors are reshaping the cybersecurity risk profile of Nepal's BFIs:

5.2.1 AI-Powered Attacks and Deepfakes

Artificial intelligence is being weaponized by cybercriminals to enhance the sophistication and scale of attacks. AI-generated deepfake audio and video are increasingly used for executive impersonation fraud — where finance teams are deceived into authorizing large transfers by fake video calls from apparent superiors. AI-generated synthetic identity fraud is also emerging, bypassing KYC controls that rely on document verification without liveness detection. AI-generated nude images targeting women — including bank employees and customers — have been weaponized for extortion, creating personal and reputational risks that intersect with financial sector security.

5.2.2 Advanced Persistent Threats (APTs)

The Sidewinder APT group, a sophisticated state-affiliated threat actor primarily targeting South Asian government and financial institutions, has been observed exploiting civil unrest conditions to distribute malware through fake emergency mobile applications. By early October 2025, Sidewinder campaigns had ensnared Android and Windows users in businesses across Kathmandu. State-sponsored probes from regional actors represent a qualitatively different threat level than opportunistic cybercriminal activity, requiring intelligence-driven defense capabilities that most Nepali BFIs currently lack.

5.2.3 Mobile Banking Exploitation

With over 23.7 million mobile banking users, mobile platforms represent the largest attack surface in Nepal's financial sector. Fake banking applications distributed through unofficial app stores, malicious SMS links, and SIM swapping attacks targeting mobile authentication are growing concerns. The prevalence of low-end smartphones with outdated operating systems and users' tendency to use public Wi-Fi for banking transactions compound mobile security risks significantly.

5.2.4 Cryptocurrency and Informal Finance Channels

The intersection of cryptocurrency with Nepal's informal economy creates complex money laundering and fraud vectors that strain existing AML/CFT frameworks. Fake crypto investment platforms proliferate through social media, exploiting regulatory gaps — Nepal does not currently have a comprehensive legal framework for cryptocurrency. The use of crypto to launder proceeds of financial cybercrime is also increasing, complicating asset recovery efforts.

6. Regulatory Progress

6.1 Legislative Framework Evolution

Nepal's primary cybersecurity legislation — the Electronic Transactions Act (ETA) 2063 (2008) — has served as the foundational legal instrument for over 15 years. While the ETA criminalizes unauthorized computer access, data theft, and electronic fraud, it predates modern cyber threats such as ransomware, APTs, AI-powered attacks, and sophisticated social engineering. A Supreme Court directive in 2023 further restricted the application of ETA Section 47 to cases involving specific, evidenced defamation or obscenity, limiting its use as a broad cybercrime catch-all.

The draft IT and Cyber Security Bill 2024 represents the most significant proposed legislative update in nearly two decades. Key provisions of the draft Bill include:

- Establishment of a National Cyber Security Centre (NCSC)
- Mandatory data breach notification requirements — currently absent from Nepali law
- Comprehensive AI governance framework
- Expanded data subject rights
- Regulated cross-border data transfer mechanisms
- Strengthened critical infrastructure protection mandates
- Creation of a dedicated Data Protection Authority

However, as of mid-2025, the Bill remains stalled in Parliament, leaving businesses and BFIs without clear standards for breach disclosure and AI governance. This legislative gap is widely cited by cybersecurity practitioners as a critical systemic weakness.

6.2 NRB's Regulatory Milestones

NRB has demonstrated growing regulatory ambition in the cybersecurity space, progressing through several landmark milestones:

Year	Milestone	Significance
2012	NRB IT Guidelines	First comprehensive IT governance framework for commercial banks; established IS audit requirements and fraud reporting obligations
2017	Post-NIC Asia Emergency Review	Emergency IT heads meeting; acceleration of security controls

Year	Milestone	Significance
		review across commercial banks
2022/23	Monetary Policy Directive #128	Mandated formulation of Cyber and Information Security Guidelines for payment-related institutions
2023 (Aug)	Cyber Resilience Guidelines (CRG)	Landmark framework aligning Nepal with BIS international standards; five risk categories and three overarching components for all licensed BFIs, PSOs, PSPs
2024	IFRS/NFRS-9 Guidance	Strengthened provisioning standards; improved financial risk management foundation
2025 (Jan)	Enhanced AML/CFT Directives	Mandatory AML/CFT departments; electronic KYC verification; enhanced PEP monitoring
2025 (Q3)	Regulatory Enforcement Actions	NPR 148.525 million fine against Standard Chartered Bank; 11 institutions penalized, signaling heightened enforcement

Table 4: NRB Regulatory Milestones in Cybersecurity and IT Governance

6.3 National Cybersecurity Policy 2023

Nepal's National Cyber Security Policy 2023 establishes a broader national framework for cybersecurity governance, including provisions for provincial-level Computer Emergency Response Teams (CERTs). In January 2025, the National Cyber Security Centre issued a 102-point advisory mandating software updates, multi-factor authentication (MFA), and incident reporting across critical infrastructure sectors. However, implementation of the provincial CERT framework remains nascent, and the Cyber Bureau continues to handle the overwhelming majority of cybercrime investigations centrally — despite a June 2024 cabinet decision authorizing all 77 districts to take initial hearings on cyber matters, which has yet to be implemented effectively.

6.4 Jurisdictional and Enforcement Challenges

A persistent structural challenge is the concentration of all cybercrime investigation capacity in the Cyber Bureau, a unit of 106 personnel including only 28 IT specialists, handling approximately 50-70 complaints daily. The investigator-to-complaint ratio of approximately 1:650 is

unsustainable. The Bureau's Superintendent of Police has publicly acknowledged that the slight dip in reported cases from FY 2023/24 to FY 2024/25 likely reflects underreporting and data lags rather than genuine improvement. The effective delegation of jurisdiction to at minimum the provincial level is urgently needed.

International coordination also remains underdeveloped. While Nepal is a member of relevant INTERPOL networks, the absence of robust mutual legal assistance treaty (MLAT) arrangements and cybercrime-specific extradition frameworks limits the ability to pursue cross-border financial cybercriminals. The NIC Asia SWIFT heist demonstrated both the effectiveness of rapid NRB intervention in freezing international transfers and the limitations of ex-post facto recovery.

7. Building Resilience — Recommendations

Achieving systemic cyber resilience in Nepal's banking and financial sector requires coordinated action across the regulatory, institutional, legislative, and societal dimensions. The following recommendations are grounded in the evidence presented in this paper and aligned with international best practices:

7.1 Legislative Priorities

- Expedite passage of the IT and Cyber Security Bill 2024, incorporating mandatory breach notification within 72 hours, a dedicated Data Protection Authority, and enforceable critical infrastructure protection standards
- Amend the Banking Offences and Punishment Act 2008 to explicitly address digital financial crimes, cryptocurrency fraud, ransomware, and AI-enabled financial deception
- Establish a dedicated Cybercrime Court or designate specialized judges with digital evidence expertise to expedite prosecution of financial cybercriminals
- Ratify the Budapest Convention on Cybercrime to strengthen international cooperation frameworks for cross-border cybercrime investigation and asset recovery

7.2 Regulatory Enhancements

- NRB should mandate Security Operations Centers (SOCs) for Class A commercial banks within 24 months, with shared SOC arrangements available for smaller Class B, C, and D institutions
- Implement mandatory annual Threat-Led Penetration Testing (TLPT) for systemically important banks, with results shared with NRB under confidentiality protocols
- Establish an NRB-facilitated sectoral Cyber Threat Intelligence Sharing Platform — modeled on the FS-ISAC framework — enabling real-time sharing of indicators of compromise (IoCs) across all licensed BFIs
- Accelerate implementation of the provincial CERT framework to decentralize cybercrime response capacity and reduce the Cyber Bureau's caseload
- Mandate third-party vendor security assessments as a condition of BFI procurement processes, with minimum security standards for all technology suppliers

7.3 Institutional Capacity Building

- Invest in substantially expanding the Cyber Bureau's IT specialist workforce — the current ratio of 28 IT experts per 18,926+ annual complaints is critically inadequate
- Establish a Nepal Cyber Security Academy or mandate that NRB, in partnership with universities, develop certified cybersecurity curricula for financial sector professionals
- Require all commercial banks to appoint a dedicated Chief Information Security Officer (CISO) with board-level reporting authority by 2026
- Implement mandatory cybersecurity awareness training for all BFI customer-facing staff, with annual refresher programs addressing current fraud typologies

7.4 Customer Protection Measures

- Develop a centralized online fraud reporting portal (modeled on India's Citizen Financial Cyber Fraud Reporting and Management System and the UK's Action Fraud platform) with a dedicated 24/7 helpline
- Expand financial literacy programs specifically addressing digital banking safety, with targeted campaigns for rural communities and elderly populations newly accessing digital financial services
- Mandate that all BFIs implement transaction velocity monitoring and anomaly detection systems, with configurable customer-defined transaction limits and instant SMS/app alerts for all transactions
- Establish a bank-funded cyber victim compensation mechanism for losses below NPR 100,000 in cases where institutional security failures are contributory

7.5 Private Sector Engagement

- Leverage Nepal's growing private cybersecurity sector — which already provides world-class SOC services to clients in the US, UK, and Australia — through public-private partnerships for affordable cybersecurity services for smaller BFIs
- Encourage banking sector consortia (such as the Nepal Bankers' Association) to establish shared cyber defense resources, including threat intelligence platforms and incident response retainer agreements
- Promote adoption of zero-trust security architecture principles across BFIs, moving away from perimeter-based security models that have proven inadequate against modern insider threats and supply chain attacks

8. Conclusion

Nepal's banking and financial sector stands at a critical inflection point. The extraordinary pace of digital financial inclusion — from mobile wallets to internet banking to real-time payment systems — has created immense social and economic value. Yet this same transformation has created a commensurate expansion of the cyber attack surface, which sophisticated and opportunistic threat actors are actively exploiting.

The data is unambiguous in its severity: NPR 1.79 billion in cyber-enabled financial fraud in a single fiscal year; nearly 19,000 cybercrime complaints annually; a 10,850% increase in reported cases since 2018/19; landmark breaches at major payment platforms and even at the NRB itself. The threat is not theoretical — it is ongoing, accelerating, and evolving.

Nepal Rastra Bank deserves recognition for its regulatory progress. The Cyber Resilience Guidelines 2023, the enhanced AML/CFT directives of 2025, the NRB IT Guidelines framework, and escalating enforcement actions represent a meaningful regulatory response. The FIU-Nepal's analytical capacity, as demonstrated by the 2024 Strategic Analysis Report, is also a valuable national asset.

However, the regulatory framework is only as effective as its implementation. Critical gaps persist: the IT and Cyber Security Bill remains unlegislated; the Cyber Bureau is critically under-resourced; provincial cyber response capacity is negligible; many BFIs lack dedicated CISOs or SOCs; and public digital literacy remains insufficient to prevent the social engineering attacks that account for a large proportion of financial fraud.

Building genuine cyber resilience in Nepal's financial sector will require a whole-of-society response — legislative action, regulatory enforcement, institutional investment, private sector partnership, and sustained public education. The cost of inaction is not merely financial: it is the erosion of trust in digital financial systems at the very moment Nepal needs that trust most, to sustain its hard-won progress toward financial inclusion and economic development.

Nepal has demonstrated that it can build world-class cybersecurity capability — its private sector firms serve global clients. The challenge is mobilizing that capability, at scale, in service of the nation's financial infrastructure. The time for incremental progress has passed; what is now required is systemic, urgently resourced transformation.

9. References & Data Sources

The following primary sources were consulted in the preparation of this research :

- Nepal Police Cyber Bureau — Annual Cybercrime Statistics (FY 2018/19 – 2024/25); Cyber-Enabled Financial Fraud Data
- FIU-Nepal — Strategic Analysis Report 2024: Cyber-Enabled Frauds (FIU-Nepal, November 2024)
- Nepal Rastra Bank (NRB) — Cyber Resilience Guidelines 2023 (August 2023)
- Nepal Rastra Bank (NRB) — Information Technology Guidelines for Commercial Banks (August 2012)
- Nepal Rastra Bank (NRB) — Enhanced AML/CFT Directives (January 2025)
- Nepal Rastra Bank (NRB) — Financial Stability Report FY 2023/24 (Issue No. 16, April 2025)
- Nepal Rastra Bank (NRB) — Banks and Financial Institutions Regulation Department: Regulatory Penalty Actions Q3 FY 2024/25
- Nepal Rastra Bank (NRB) — Monetary Policy FY 2022/23 (Directive #128: Cyber and Information Security Guidelines)
- Nepal Police Cyber Bureau — Cybercrime Category-wise Annual Reports (fiscal years 2019/20 through 2024/25)
- National Cyber Security Centre (NCSC) Nepal — 102-Point Advisory on Cybersecurity Best Practices (January 2025)
- National Cybersecurity Policy 2023 (Government of Nepal)
- Electronic Transactions Act 2063 (2008) (Government of Nepal)
- Banks and Financial Institutions Act (BAFIA) 2073 / 2017 (Government of Nepal)
- Individual Privacy Act 2075 / 2018 (Government of Nepal)
- KPMG India — Forensic Investigation Report: NIC Asia Bank SWIFT Compromise (2017, commissioned by NIC Asia Bank)
- Bank for International Settlements (BIS) — Guidance on Cyber Resilience for Financial Market Infrastructures (2016/2021)
- Kathmandu Post — Reporting on Cybercrime Trends, NIC Asia SWIFT Heist, and NRB Regulatory Actions (2017–2025)
- Fiscal Nepal — Analysis of NRB Regulatory Milestones and BFI Penalty Actions (2024–2025)
- Global IME Bank — "Cybersecurity Resilience in Nepal: A Critical Imperative for a Rapidly Digitalizing Economy" (February 2026)

— End of Research —